

Data Leak Worksheet – Zimbabwe Commercial Bank ABC

Incident Summary

A manager at a ABC commercial bank in Zimbabwe shared access to an internal folder with members of the marketing and sales team during a virtual meeting. The folder contained confidential documents related to a new banking product that had not yet been publicly announced. The folder also included customer analytics reports, internal financial projections, and promotional materials intended for future public release.

After the meeting, the manager forgot to remove employee access to the internal folder. Although employees were instructed not to share the information until official approval was given, one sales employee accidentally shared a link to the entire internal folder during a video call with a business partner.

The employee intended to share only the approved promotional material but mistakenly copied the link to the confidential folder instead. The business partner, believing the information was public, shared the link on their company's social media page.

As a result, confidential banking information and customer-related analytics became publicly accessible.

Control: Least Privilege

Issue(s)

The data leak occurred because employees were given broader access than necessary. Instead of restricting access to only the required promotional file, the manager shared the entire folder containing sensitive internal documents.

Additionally:

- Access permissions were not removed after the meeting.
- The employee was able to access and share confidential files unrelated to their immediate task.
- There were no automated controls preventing external sharing of sensitive internal data.

This failure violated the principle of **Least Privilege**, where users should only have the minimum level of access necessary to perform their duties.

Review

NIST SP 800-53: AC-6 – Least Privilege

National Institute of Standards and Technology SP 800-53 AC-6 emphasizes that users should only be granted the minimum access required to complete their work tasks.

The guideline recommends:

- Restricting access to sensitive information based on employee roles
- Monitoring user permissions regularly
- Automatically revoking temporary access
- Logging and auditing user activities

The goal is to reduce the risk of accidental or intentional exposure of sensitive information.

Recommendations

1. Implement Granular File-Level Access Controls

Employees should only access specific files required for their work instead of entire folders containing confidential banking information.

Example

- Marketing staff should only access approved promotional materials.
- Financial analytics and internal strategy documents should remain restricted to management and authorized departments.

2. Establish Automatic Access Expiration

Temporary access permissions should automatically expire after meetings, projects, or collaborations end.

Benefits

- Reduces forgotten permissions
- Limits unnecessary long-term access
- Protects confidential banking information

3. Conduct Regular Access Reviews

The IT department should regularly review:

- User permissions
- Shared folders
- External sharing settings

This helps identify unnecessary or excessive access rights.

4. Enable Data Loss Prevention (DLP) Controls

The bank should implement DLP technologies that:

- Detect sensitive banking information
 - Prevent unauthorized external sharing
 - Alert administrators about risky activities
-

5. Provide Employee Security Awareness Training

Employees should receive training on:

- Secure file sharing practices
 - Data classification
 - Handling confidential banking information
 - Recognizing accidental data exposure risks
-

Justification

Granular file-level permissions would have prevented the employee from accessing and sharing confidential internal documents unrelated to their task.

Automatic access expiration and regular permission reviews would have reduced the chance of forgotten access rights remaining active.

Data Loss Prevention systems could have detected the attempt to share sensitive internal banking files externally before the leak occurred.

Together, these controls:

- Reduce human error
- Strengthen least privilege enforcement
- Protect customer and financial information

- Reduce reputational and regulatory risks for the bank
-

Security Plan Snapshot

Function Category		Subcategory	Reference
Protect	PR.DS: Data Security	PR.DS-5: Protections against data leaks	NIST SP 800-53: AC-6

NIST SP 800-53: AC-6 – Least Privilege

Control

Users should only receive the minimum level of access and authorization necessary to complete their assigned duties.

Discussion

User accounts, permissions, and roles should be carefully managed to ensure employees cannot access information beyond what is required for their job responsibilities.

This helps:

- Prevent accidental data leaks
 - Reduce insider threats
 - Limit unauthorized access
 - Protect sensitive banking data
-

Control Enhancements

- Restrict access based on employee roles
 - Automatically revoke temporary permissions
 - Maintain activity logs for user actions
 - Regularly audit user privileges and permissions
-

Conclusion

The incident at the Zimbabwe commercial bank demonstrates how excessive access permissions and human error can lead to serious data leaks. Sensitive customer analytics and confidential business information became publicly accessible because proper least privilege controls were not enforced.

By implementing stronger access controls, automated permission management, employee training, and data protection technologies, the bank can significantly reduce the risk of future data exposure incidents and improve its overall cybersecurity posture.